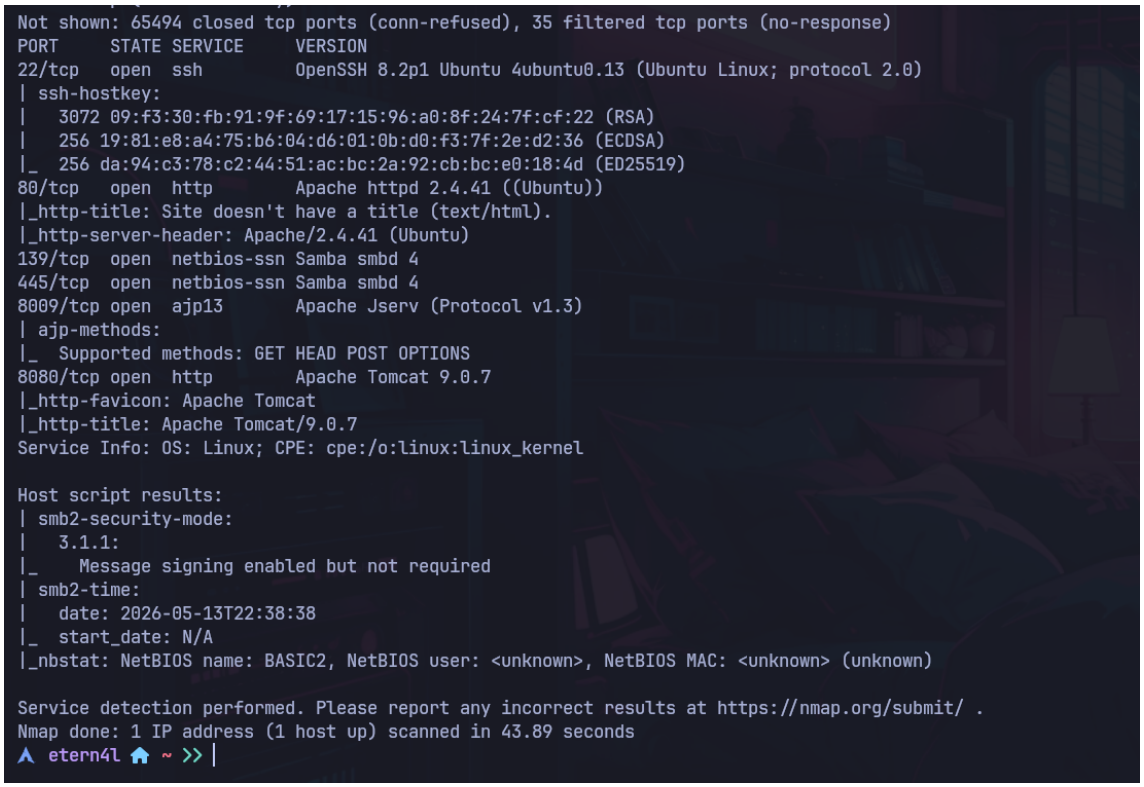
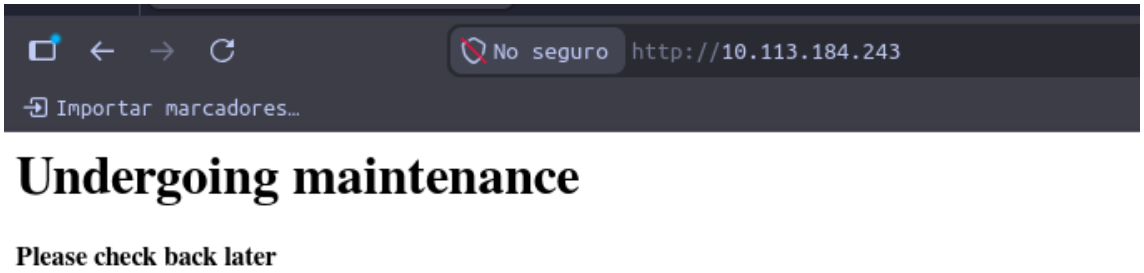
Comenzamos con la enumeración donde vemos varios puertos bastante interesantes con los que podríamos empezar a hacer un reconocimiento y enumerar de forma mas profunda.



Al revisar la pagina web nos la encontramos en mantenimiento.



Pero observamos en el código fuente de la pagina una nota que nos indica lo siguiente: “Check our dev note section if you need to know what to work on.”

```
<html>

<h1>Undergoing maintenance</h1>

<h4>Please check back later</h4>

<!-- Check our dev note section if you need to know what to work on. -->


</html>

```

Realizamos fuzzing con gobuster y se encuentra un directorio llamado “development” que procedemos a investigar.

```
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htpasswd.html       (Status: 403) [Size: 279]
.htpasswd            (Status: 403) [Size: 279]
.htaccess            (Status: 403) [Size: 279]
.htpasswd.txt        (Status: 403) [Size: 279]
.htaccess.php        (Status: 403) [Size: 279]
.htpasswd.php        (Status: 403) [Size: 279]
.htaccess.html       (Status: 403) [Size: 279]
.htaccess.txt        (Status: 403) [Size: 279]
development          (Status: 301) [Size: 322] [--> http://10.113.184.243/development/]
index.html           (Status: 200) [Size: 158]
server-status        (Status: 403) [Size: 279]
Progress: 81924 / 81924 (100.00%)
===============================================================
Finished
===============================================================
 eternal  ~ >>
```

Se encuentran dos archivos de texto que si lo revisamos observamos que son notas del desarrollador.

Procedemos a revisarlas



```
2018-04-23: I've been messing with that struts stuff, and it's pretty cool! I think it might be neat
to host that on this server too. Haven't made any real web apps yet, but I have tried that example
you get to show off how it works (and it's the REST version of the example!). Oh, and right now I'm
using version 2.5.12, because other versions were giving me trouble. -K

2018-04-22: SMB has been configured. -K

2018-04-21: I got Apache set up. Will put in our content later. -J
```

La última nota revela que la contraseña del usuario J es débil y puede ser fácilmente crackeada

```
For J:

I've been auditing the contents of /etc/shadow to make sure we don't have any weak credentials,
and I was able to crack your hash really easily. You know our password policy, so please follow
it? Change that password ASAP.

-K
```

SMB - 139/445

Proseguimos con la enumeración del servicio SMB identificando recursos compartidos accesibles sin autenticación para verificar posibles accesos anónimos.

```
eternal ~ >> smbclient -L //10.113.184.243/ -N
Can't load /etc/samba/smb.conf - run testparm to debug it

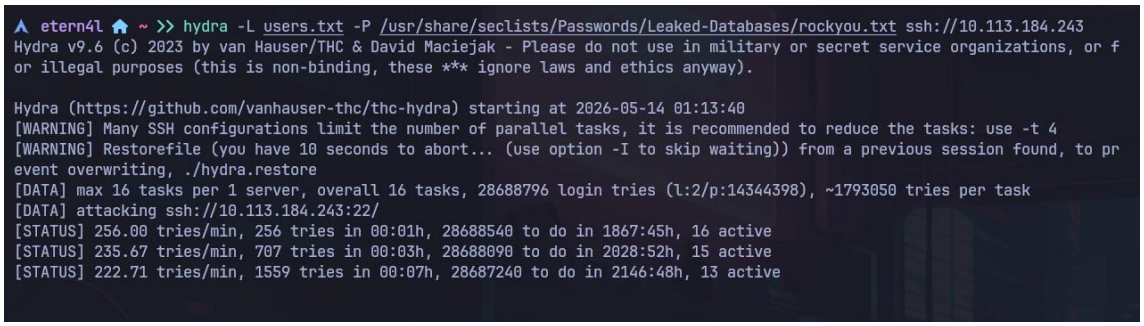
        Sharename       Type      Comment
        ---------       ----      -------
        Anonymous       Disk
        IPC$            IPC       IPC Service (Samba Server 4.15.13-Ubuntu)
SMB1 disabled -- no workgroup available
```

Tras acceder al recurso compartido “Anonymous” , encontramos un archivo “staff.txt” dirigido al staff. En la nota se menciona a los usuarios `Kay` y `Jan`, identificando así posibles usuarios válidos del sistema.

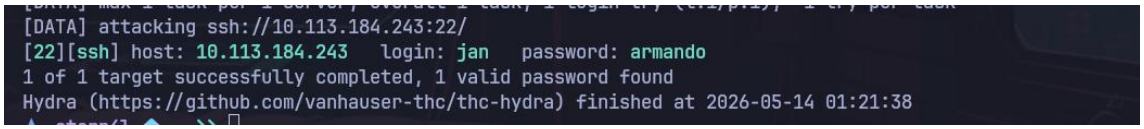
```
File: staff.txt

1  Announcement to staff:
2
3  PLEASE do not upload non-work-related items to this share. I know it's all in fun, but
4  this is how mistakes happen. (This means you too, Jan!)
5
6  -Kay
```

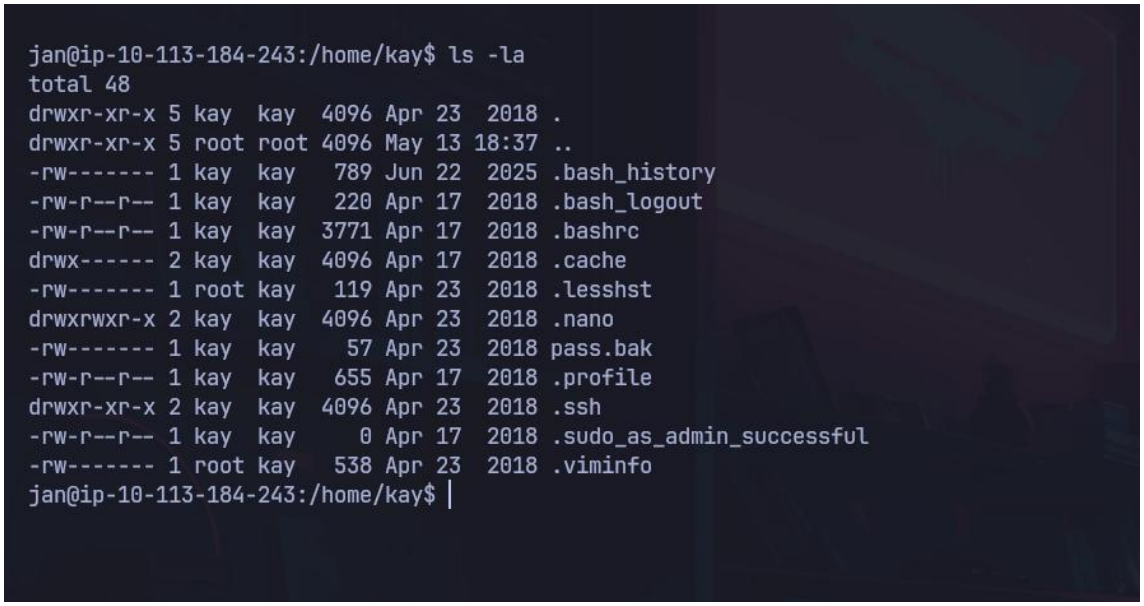
Recordando anteriormente que uno de los usuarios disponía de unas credenciales débiles procedemos a realizar un ataque de fuerza bruta a ambos usuarios a través de **ssh.**



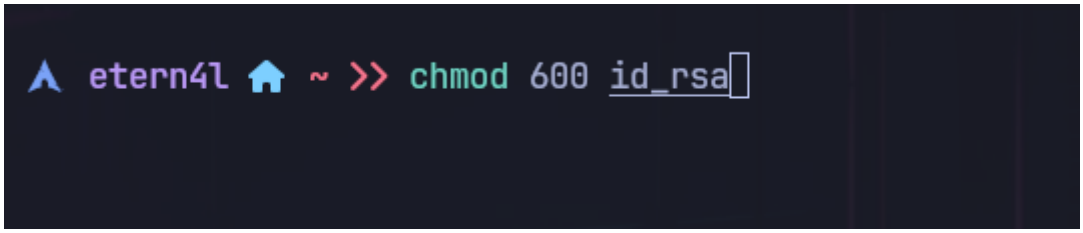
Obtenemos las credenciales para poder acceder a través de ssh



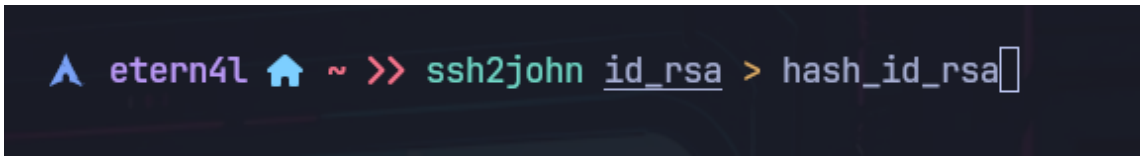
Una vez conseguimos entrar por ssh, investigando en el directorio “home” encontramos archivos interesantes como “pass.bak” que para ello necesitamos ser el usuario kay



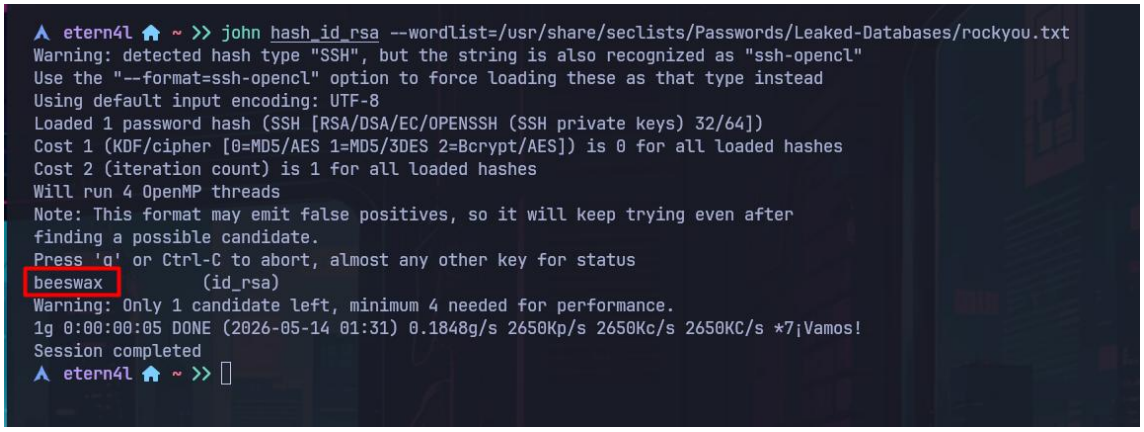
Observamos que podemos utilizar la clave id_rsa para acceder como usuario **Kay**. Antes de proceder, debemos asegurarnos de otorgar los permisos necesarios para utilizar la clave de forma adecuada.

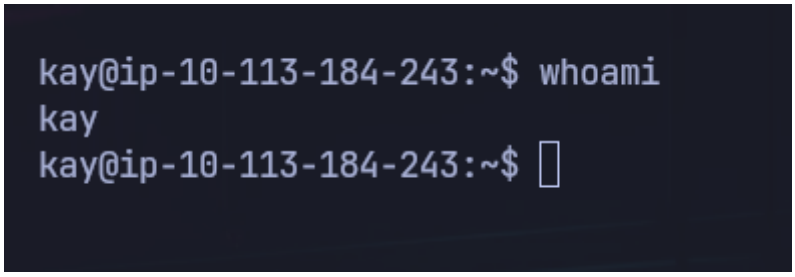


Pero la clave id_rsa esta encriptada y necesitamos la contraseña para desencriptarla. Podemos usar “ssh2john” para convertir la clave en un formato compatible con “John The Ripper” y de esta forma poder intentar crackearla.



Conseguimos crackear la contraseña para poder conectarnos por ssh con la clave id_rsa del usuario kay.





Una vez accedido podemos leer el archivo “pass.bak” que vimos anteriormente en el que solo tenía acceso el usuario kay.

